MODULE 38 · EXAM STRATEGY - ALL DOMAINS

Practice Exam 3

Twenty questions. Heavier on operations detail and the services added in exam guide v1.1.

QUESTIONS 20 SUGGESTED TIME 40 minutes PASS GUIDE 14 of 20

admin@sthithapragna.com

> An application already writes structured JSON to CloudWatch Logs, including a field for the duration of each order. The team wants a CloudWatch metric for order duration without adding a metrics library or making extra API calls from the application.
>
> Log volume is high and cost matters.

What should the team use?

A PutMetricData called from the application for each order

B A CloudWatch alarm reading the log group directly

C Embedded Metric Format, so CloudWatch extracts metrics from the logs already being written

D A Lambda function polling Logs Insights every minute

◆ PAUSE AND DECIDE

What should the team use?

A PutMetricData per order

Adds a synchronous API call to every order, which is exactly the extra call the requirement excludes, and it is charged per request.

B Alarm on the log group

Alarms evaluate metrics, not log groups. Something must turn log data into a metric first.

C Embedded Metric Format

EMF lets you emit metrics inside log events you are already writing. CloudWatch extracts them, with no separate API call.

D Poll Logs Insights

Builds a metric pipeline by hand, adds latency, and pays for a query every minute.

THE SIGNAL

"Already logging the value" is the EMF signal. PutMetricData is for values you are not otherwise recording.

A platform team must view CloudWatch metrics, logs and traces from 40 member accounts in a single account, without granting engineers access to each member account. Engineers should see cross-account dashboards natively in the CloudWatch console.

All accounts are in one AWS Organization.

What should the team configure?

A CloudWatch cross-account observability: a monitoring account sink, with source account links

B A metric stream from each account to a central Firehose

C A cross-account IAM role in each member account for engineers to assume

D Amazon Managed Grafana with 40 CloudWatch data sources

◆ PAUSE AND DECIDE

What should the team configure?

A Sink and links

Purpose-built: a sink in the monitoring account, links from each source account, and metrics, logs and traces appear natively in one console.

B Metric streams to Firehose

Streams metrics to a destination for storage or third-party tools. It does not carry logs or traces, nor produce native cross-account views.

C Cross-account roles

Requires engineers to switch accounts one at a time, which is the access model the requirement rules out.

D Managed Grafana

Genuinely works and adds a service and per-user cost for something CloudWatch does natively across accounts.

THE SIGNAL

Sink in the monitoring account, links in the sources. Grafana is the answer when the data is heterogeneous, not merely cross-account.

> An investigator needs to determine who deleted a specific S3 object 100 days ago. The account has never configured a CloudTrail trail, and the team is relying on CloudTrail Event history in the console.
>
> Event history shows nothing relevant.

Why, and what should have been in place?

A Event history covers 180 days, so the record has only just expired

B Object deletions are management events and should be visible

C CloudTrail Lake should have been enabled instead

D Event history covers 90 days and management events only. A trail logging S3 data events was required

◆ PAUSE AND DECIDE

Why, and what should have been in place?

A 180 days

Event history covers 90 days, not 180. Even at 180 the object-level event would still be absent for the second reason.

B Deletions are management events

The core error. Object-level operations are data events, which are off by default and charged from the first copy.

C CloudTrail Lake

Would provide longer retention, and it closed to new customers on 31 May 2026. It also would still need data events enabled.

D 90 days, management only; needed a data event trail

Two independent reasons: the retention window and the event category. Both had to be addressed in advance.

THE SIGNAL

Two failures, not one. Event history is 90 days AND management events only, so object-level activity was never captured at all.

A team currently patches 900 EC2 instances using maintenance windows, patch groups and a hand-maintained set of tags. Onboarding a new account takes a day of configuration, and drift between accounts is common.

They want the approach AWS currently recommends for a new multi-account patching design.

What should they adopt?

A More maintenance windows, one per account, driven by StackSets

B Patch policies configured through Systems Manager Quick Setup, with separate scan and install schedules

C A Lambda function invoking Run Command with the patch baseline document

D State Manager associations applying patches on a schedule

◆ PAUSE AND DECIDE

What should they adopt?

A More maintenance windows

Automates the existing complexity rather than removing it. Patch groups and per-account windows are what the new design is meant to replace.

B Patch policies via Quick Setup

AWS's recommended path: organisation-wide configuration, separate scan and install schedules, and no patch groups to maintain.

C Lambda plus Run Command

Rebuilds patching by hand, with a function to maintain and no reporting or compliance view.

D State Manager associations

Enforces state continuously and is a reasonable mechanism. It is not the managed patching path, and it lacks patch policy's reporting.

THE SIGNAL

Patch policies are the current recommended path. Maintenance windows and patch groups are the older design they replace.

> A team is adding distributed tracing to new microservices on EKS in 2026. They want traces in X-Ray today, and the freedom to send telemetry to a different backend later without re-instrumenting the code.
>
> An engineer proposes adding the AWS X-Ray SDK to each service.

What should the team do?

A Proceed with the X-Ray SDK, since X-Ray is the AWS-native tracing service

B Use CloudWatch Container Insights, which provides tracing

C Instrument with OpenTelemetry and deploy the ADOT Collector, exporting traces to X-Ray

D Send traces to Amazon Managed Service for Prometheus

◆ PAUSE AND DECIDE

What should the team do?

A X-Ray SDK

The SDKs and daemon entered maintenance mode in 2026: security fixes only. Building new instrumentation on a frozen library, and it locks the backend in.

B Container Insights

Provides cluster, node and pod metrics. It does not produce distributed traces.

C OpenTelemetry with ADOT

Vendor-neutral instrumentation with X-Ray as today's exporter. Changing backend later becomes a configuration change.

D Prometheus for traces

Prometheus is a metrics system and PromQL is a metrics language. Neither handles traces.

THE SIGNAL

Be precise: the X-Ray SDKs are frozen, and the X-Ray service is fully supported. The answer still sends traces to X-Ray.

> Instances in an Auto Scaling group take six minutes to become useful. Four of those minutes are spent installing packages, runtimes and the application itself; the remaining two load the current day's reference data into a local cache.
>
> The team wants to reduce scale-out time as far as practical.

What should the team do?

A Use a warm pool only, since it addresses all six minutes

B Increase the instance size so installation completes faster

C Use a golden AMI only, since it addresses all six minutes

D Bake the installation into a golden AMI, and use a warm pool for the data loading

◆ PAUSE AND DECIDE

What should the team do?

A Warm pool only

Would work, and it pays to keep stopped instances holding software that could simply have been baked into the image.

B Bigger instances

Speeds installation somewhat and pays for larger instances permanently to fix a one-off cost at launch.

C Golden AMI only

Removes the four minutes of installation. The two minutes of loading current data cannot be baked, because it depends on today's data.

D Both, for different halves

Installation belongs in the image; loading current data cannot. The scenario splits the six minutes deliberately.

THE SIGNAL

Ask what the boot time is spent on. Installing software belongs in the image. Loading today's data does not, and that is the warm pool case.

A 60-instance Auto Scaling group must receive a new AMI during business hours. Capacity must never fall below current levels, the rollout must pause after the first quarter for review, and it must reverse automatically if error rates rise.

The group is defined in CloudFormation and the stack must stay consistent with reality.

What should the team use?

A. The AutoScalingInstanceRefresh update policy with MinHealthyPercentage 100, checkpoints and an alarm specification

B. The AutoScalingRollingUpdate policy with MaxBatchSize 15

C. Run an instance refresh manually from the console after updating the stack

D. Create a second Auto Scaling group and shift ALB target group weights

◆ PAUSE AND DECIDE

What should the team use?

A AutoScalingInstanceRefresh policy

MinHealthyPercentage 100 gives launch-before-terminate, checkpoints give the review pause, and the alarm specification gives automatic reversal, all inside the stack.

B AutoScalingRollingUpdate

Terminates before launching, so capacity dips, and it offers neither checkpoints nor alarm rollback. It also suspends scaling policies.

C Manual refresh

Gets the deployment right and breaks the requirement that the stack stays consistent. This is the drift the newer policy exists to remove.

D Second group plus weights

A valid blue/green pattern that doubles the fleet and duplicates the stack, which is far more machinery than the requirements ask for.

THE SIGNAL

Four requirements, and only the July 2026 update policy meets all four without leaving CloudFormation.

A DynamoDB table in on-demand capacity mode normally serves about 900 reads per second. During a product launch, traffic rises to roughly 50,000 reads per second within twenty seconds. Customers see errors and CloudWatch shows ReadThrottleEvents for several minutes.

The team believed on-demand mode could not throttle.

What explains this, and what should they have done?

A On-demand tables have a hard 40,000 read limit that cannot be raised

B The table's warm throughput was too low for the spike. Pre-warm the table before a known event

C Switch to provisioned mode with auto scaling and a low target utilisation

D Add a global secondary index to spread the read load

◆ PAUSE AND DECIDE

What explains this, and what should they have done?

A Hard 40,000 limit

There is a default account-level limit near that figure and it is raisable on request, so "cannot be raised" makes this wrong.

B Warm throughput too low; pre-warm

On-demand scales, but not instantly. Warm throughput is what a table serves immediately, and pre-warming raises it ahead of a known event.

C Provisioned with auto scaling

Worse for this shape. Provisioned auto scaling reacts after about two minutes, which is slower than on-demand rather than faster.

D Add a GSI

An index serves different query patterns. It does not add capacity for the same reads, and it adds write cost.

THE SIGNAL

"On-demand cannot throttle" is the misconception being tested. It means it always eventually scales, not that it never throttles.

A team is designing a multi-Region recovery plan in 2026 and wants continuous confirmation that the secondary Region remains capable of taking over: correct service quotas, sufficient capacity and matching routing configuration.

An architect recommends ARC readiness checks, which they used successfully at a previous employer.

What should the team do?

A Implement ARC readiness checks as recommended

B Use Route 53 health checks against the secondary Region's endpoint

C Onboard to ARC Region switch and use its plan evaluation capability

D Use AWS Config conformance packs in the secondary Region

◆ PAUSE AND DECIDE

What should the team do?

A ARC readiness checks

Closed to new customers on 30 April 2026. A team designing a new plan cannot onboard, whatever the architect used previously.

B Route 53 health checks

Confirms an endpoint responds. It says nothing about quotas, capacity or configuration parity.

C Region switch plan evaluation

AWS's own recommended replacement. Plan evaluation continually monitors that the recovery plan remains executable.

D Conformance packs

Checks resource configuration against rules, which helps. It does not evaluate quotas, capacity or readiness to fail over.

THE SIGNAL

The architect's recommendation is voiced by a character, which is the signal to test it rather than accept it. ARC itself is fully supported; only readiness check closed.

A developer creates a new CloudFormation stack. It fails because an S3 bucket name is already taken, and CloudFormation rolls back. The stack now shows ROLLBACK_COMPLETE. The developer corrects the bucket name and attempts a stack update, which is rejected immediately.

No resources from the stack remain.

What should the developer do?

A Call ContinueUpdateRollback to clear the state

B Create a change set against the existing stack and execute it

C Enable disable-rollback and retry the update

D Delete the stack and create it again with the corrected template

◆ PAUSE AND DECIDE

What should the developer do?

A ContinueUpdateRollback

Applies to UPDATE_ROLLBACK_FAILED, a different state. There is no update rollback in progress to continue.

B Change set and execute

A change set is still an update, and updates are not permitted from this state. It is rejected identically.

C Disable rollback and retry

Useful on the next attempt to preserve resources for debugging. It does not make an update legal from ROLLBACK_COMPLETE.

D Delete and recreate

ROLLBACK_COMPLETE permits deletion only. There is no repair path, and the stack contains nothing worth preserving.

THE SIGNAL

ROLLBACK_COMPLETE and UPDATE_ROLLBACK_FAILED sound almost identical and are completely different. One is a dead end; the other has a documented way out.

> Development teams need to create RDS databases on demand. The security team will not grant rds:CreateDBInstance to developers. Every database must use approved instance classes, be encrypted, and carry a cost centre tag.
>
> The platform team already has a CloudFormation template that satisfies all of this.

What should the platform team implement?

A. A Service Catalog portfolio with the template as a product, a launch constraint, and a template constraint on instance classes

B. Grant rds:CreateDBInstance with an IAM condition restricting instance classes

C. A StackSet deploying the template into every development account

D. A CDK construct published to an internal package repository

◆ PAUSE AND DECIDE

What should the platform team implement?

A Service Catalog with both constraints

The launch constraint means developers never hold the permission, and the template constraint limits instance classes. Self-service without privilege.

B Grant with conditions

Directly contradicts the stated constraint. The security team will not grant it, conditioned or otherwise.

C A StackSet

Pushes the same resources to every account on the platform team's schedule. It is not on-demand self-service.

D A CDK construct

Standardises the code and still requires whoever deploys it to hold the underlying permissions. It solves consistency, not privilege.

THE SIGNAL

The stated refusal to grant the permission is the whole question. Only a launch constraint provisions with a role the requesting user does not have.

A security team enables an SCP permitting only AMIs owned by the company's own accounts. Shortly afterwards, an EKS Auto Mode cluster stops provisioning nodes and an ECS Managed Instances capacity provider stops scaling.

No other change was made.

What is the cause, and what is the fix?

A Those services require the SCP to be removed entirely

B SCPs apply to the infrastructure roles those services use. Permit the AWS-owned AMI accounts as well

C The clusters need a Kubernetes version upgrade

D Service-linked roles are exempt from SCPs, so this cannot be the cause

◆ PAUSE AND DECIDE

What is the cause, and what is the fix?

A Remove the SCP

Weakens a legitimate control to accommodate a service. The AMI accounts can simply be permitted instead.

B SCPs govern infrastructure roles; permit the AMI accounts

Managed compute launches instances using a role in your account, and SCPs apply to that role. The AWS-owned AMI accounts must be permitted.

C Version upgrade

Nothing about a version changed. The timing points at the policy, which is the only change described.

D Roles are exempt from SCPs

Confuses two similar things. SCPs skip service-linked roles, but do apply fully to infrastructure roles, which is why this breaks.

THE SIGNAL

Service-linked roles are exempt from SCPs. Infrastructure roles are not. Two similar-sounding things behaving oppositely.

> A team wants to expose a redesigned checkout flow to 10 percent of users, monitor conversion for a week, then expand or withdraw it. Both the old and new flows are already deployed and passing tests. Withdrawing the feature must not require a deployment.
>
> The application runs on ECS behind an ALB.

What should the team use?

A. A canary deployment shifting 10 percent of traffic to a new task set

B. Blue/green with the green environment serving 10 percent

C. Weighted target groups on the ALB

D. AWS AppConfig feature flags, with a deployment strategy and CloudWatch alarm rollback

◆ PAUSE AND DECIDE

What should the team use?

A Canary deployment

The closest competitor, and it splits traffic between versions. Both flows are already in the same deployed version, so there is nothing to split.

B Blue/green at 10 percent

Runs two full environments for a week, and withdrawing still means a traffic switch rather than a configuration change.

C Weighted target groups

The mechanism underneath a canary. Same objection: both flows live in the same tasks already.

D AppConfig feature flags

The code is already deployed. A flag turns the feature on for a subset and off again instantly, with no deployment either way.

THE SIGNAL

"Both flows are already deployed" is the clause. Nothing needs deploying, so no deployment strategy is the answer.

A compliance regime requires the KMS key protecting a database to have its key material rotated every 90 days. An engineer states that KMS only rotates annually, and proposes a Lambda function to create a new key each quarter and re-encrypt all data.

The key is a customer managed symmetric encryption key.

What should the team do?

A Enable automatic rotation with a 90-day rotation period

B Build the Lambda function as proposed

C Switch to an AWS managed key, which rotates more frequently

D Use an external key store, which supports custom rotation

◆ PAUSE AND DECIDE

What should the team do?

A Automatic rotation, 90-day period

Since April 2024 the rotation period is configurable from 90 to 2,560 days on customer managed symmetric keys. This is a single setting.

B Build the Lambda

Solves a problem that no longer exists, with a function that re-encrypts an entire database quarterly. Considerable risk for nothing.

C AWS managed key

Rotates yearly and cannot be changed, so it is further from the requirement, and it removes your control of the key policy.

D External key store

Places key material outside AWS for sovereignty requirements. It does not provide a shorter automatic rotation period.

THE SIGNAL

The engineer's premise was true until April 2024. A requirement that once needed custom tooling is now a single setting.

> A secret in Secrets Manager in account B must be read by an application role in account A. A resource policy has been added to the secret permitting the role. Requests still fail with AccessDenied.
>
> The secret is encrypted with the default aws/secretsmanager key.

What is the cause?

A The role in account A needs secretsmanager:CreateSecret

B A secret encrypted with the default AWS managed key cannot be shared cross-account. Use a customer managed key

C The secret must be replicated into account A

D Cross-account access to Secrets Manager is not supported

◆ PAUSE AND DECIDE

What is the cause?

A Needs CreateSecret

Reading a secret needs GetSecretValue. CreateSecret makes new ones and would not help.

B Default managed key blocks cross-account

A secret is always encrypted, so reading it requires decrypt on the key. AWS managed key policies cannot be edited to permit another account.

C Replicate the secret

Replication puts a copy in another Region, not another account. It does not address cross-account access at all.

D Not supported

Fully supported, via a resource policy on the secret plus permission on a customer managed key.

THE SIGNAL

Anything encrypted needs the key checked too. A secret that might ever be read cross-account must use a customer managed key from the start.

> An organisation must guarantee that IMDSv2 is required on every EC2 instance in every account, now and in future. A previous attempt used an SCP denying RunInstances without the correct metadata options, and new launch paths and new APIs repeatedly bypassed the wording.
>
> New accounts join the organisation most weeks.

What should the organisation use?

A. A more comprehensive SCP covering every launch API

B. An AWS Config rule with automatic remediation

C. A declarative policy setting instance metadata defaults across the organisation

D. A CloudFormation Hook rejecting non-compliant templates

◆ PAUSE AND DECIDE

What should the organisation use?

A A better SCP

The approach that already failed, written more carefully. It still enumerates calls, so a future API needs another policy update.

B Config rule with remediation

Detective then corrective. Non-compliant instances exist before being fixed, which the requirement does not accept.

C Declarative policy

Declares the setting's value rather than denying calls, and is maintained as the service adds new APIs and as accounts join.

D CloudFormation Hook

Preventive, and only for resources created through CloudFormation. Console and CLI launches bypass it entirely.

THE SIGNAL

The scenario states the failure mode of enumeration: new APIs slip past. That is exactly the gap declarative policies were built to close.

A security team must guarantee that no resource in any VPC across the organisation can be reached from the internet. A small number of documented exceptions are allowed. Route tables and security groups are managed by many application teams, and new accounts are created weekly.

Outbound internet access through NAT gateways must continue to work.

What should the team implement?

A An SCP denying ec2:CreateRoute for internet gateway destinations

B A Config rule detecting route tables with an internet gateway route

C Delete all internet gateways in all accounts

D VPC Block Public Access in Block Ingress mode with exclusions, deployed as a declarative policy

◆ PAUSE AND DECIDE

What should the team implement?

A Deny CreateRoute

Stops new routes and does nothing about routes that already exist. It also blocks the documented exceptions entirely.

B Config rule

Detective. It reports a publicly reachable resource after it exists, and the requirement is that none can be reached.

C Delete internet gateways

Breaks every NAT gateway and every legitimate outbound path, which the final sentence explicitly forbids.

D Block Public Access, Block Ingress, declarative

Overrides route tables and security groups directly, exclusions cover the documented cases, and a declarative policy covers accounts created later.

THE SIGNAL

Block Ingress is the mode that matters: inbound is blocked while NAT and egress-only gateways keep working, which the last sentence requires.

A new application server cannot connect to a database. It has never worked once. The environment spans two VPCs joined by peering, with several security groups, custom network ACLs and route tables owned by different teams. An engineer has spent two hours reading configuration.

VPC Flow Logs are not currently enabled.

What is the most efficient next step?

A Enable VPC Flow Logs and look for REJECT records

B Temporarily open all security groups to 0.0.0.0/0 to isolate the layer

C Run Reachability Analyzer between the application instance and the database, and read the blocking component it names

D Enable Traffic Mirroring on the application instance

◆ PAUSE AND DECIDE

What is the most efficient next step?

A Flow logs for REJECT

Useful, and it shows only the first blocking point that generates a record. A missing route produces no REJECT at all.

B Open everything temporarily

The genuinely dangerous answer. It creates a real exposure, and if the cause is routing it changes nothing while you believe you tested it.

C Reachability Analyzer

Never worked means configuration. The analyzer evaluates the whole path across both VPCs and names the blocking component in seconds.

D Traffic Mirroring

Captures packet contents on a path that is not passing packets. There is nothing to mirror.

THE SIGNAL

"It has never worked" means configuration. Flow logs are for things that used to work, or work sometimes.

> An internet-facing Application Load Balancer sits behind CloudFront. A WAF rule on the ALB blocks any request lacking a secret custom header that CloudFront adds. A security review objects that the ALB remains publicly reachable and that the header has not been rotated in two years.
>
> The application must remain behind CloudFront.

What should the team implement?

A Rotate the custom header automatically with a Lambda function

B Make the ALB internal and configure it as a CloudFront VPC origin

C Attach an Origin Access Control to the ALB

D Restrict the ALB's security group to CloudFront's published IP ranges

◆ PAUSE AND DECIDE

What should the team implement?

A Rotate the header

Genuinely improves the existing design, and the ALB stays publicly reachable. It fixes the stale secret, not the exposure.

B Internal ALB as a VPC origin

Removes the public endpoint entirely. The ALB has no public address, so there is nothing to reach and no secret to protect.

C OAC on the ALB

Origin Access Control signs requests to S3 origins. It does not apply to a load balancer.

D CloudFront IP ranges

The subtle one. Those ranges admit every CloudFront distribution in the world, including someone else's pointed at your ALB.

THE SIGNAL

Option D is why the secret header pattern existed in the first place. VPC origins remove the public endpoint rather than guarding it.

> A team creates a private hosted zone for example.com and associates it with a VPC. Instances resolve app.example.com internally, as intended. They can no longer resolve mail.example.com, a public record the team does not manage in the private zone.
>
> External systems resolve mail.example.com normally.

What is the cause and the fix?

A. The private hosted zone is authoritative for the whole domain inside the VPC. Add the missing records to it

B. enableDnsHostnames is disabled on the VPC

C. Add a Resolver forwarding rule pointing at the public zone

D. The VPC needs an outbound Resolver endpoint

◆ PAUSE AND DECIDE

What is the cause and the fix?

A The private zone is authoritative for the whole domain

Inside an associated VPC the private zone answers for example.com entirely. Names not defined in it do not resolve, even if they exist publicly.

B enableDnsHostnames disabled

Would prevent the private zone working at all. app.example.com resolves correctly, so the attribute is enabled.

C Forward to the public zone

Resolver forwarding rules send queries to DNS servers you specify. There is no mechanism to fall through from a private zone to a public one.

D Outbound endpoint

Sends queries to on-premises DNS servers. The missing record is on the public internet, which the resolver already reaches.

THE SIGNAL

Overlaying a private zone on a public domain is a decision to own every name in it. There is no fall-through, and that surprises people.

What this set was testing

- **Five questions turned on a stated belief being wrong**: the X-Ray SDK, ARC readiness check, on-demand throttling, KMS annual rotation, and CloudTrail Event history.
- **Three questions had an answer voiced by a character** - an engineer or architect recommending something. Treat a quoted recommendation as a hypothesis to test.
- **Two questions split a requirement in half** deliberately, so the answer needed two mechanisms rather than one.
- **One question offered a genuinely dangerous option**: opening every security group to isolate a fault. It creates real exposure and proves nothing.

> ON THE EXAM
>
> If you missed several of the first group, module 33 is your revision. If you missed the character-voiced ones, re-read module 35 on distractor patterns.